CASE STUDY :- "The attack on Bright Mart Online"

Topics Covered.

Scenario :- BrightMart is a medium-sized online shopping company. Customers use its website & mobile application to purchase products.

The company stores :-

- Customer names
- Email addresses
- Phone number
- Delivery addresses
- Passwords
- order info
- Payment-related info

BrightMart has around 100 employees.

The company recently recently hired several new employees. To make things easier, the IT department gave employees access to different internal systems.

However, the company has the following security weakness.

- Some employees use simple passwords such as Brightmart123
- Many employees use the same password for multiple sys
- Software updates are sometimes delayed.
- Employees can access sensitive info that they do not necessarily need for their jobs.
- Backups are performed only once a month.

The Incident

One Monday morning, an employee named Rahul receives an email.

Subject :- Urgent - Your Acc will Be Suspended

The email appears to come from the company's IT department.

It says :- "Your company acc will be suspended today. Click the link below & verify your password immediately"

Rahul click the link.

The page looks almost identical to the company's login page. He enters his username & password.

Rahul does not realize that the website is controlled by an attacker.

The attacker now has Rahul's login credentials.

Stage 1 :- Unauthorized Access

The attacker uses Rahul's credentials to access Bright-Mart's internal sys.

Because Rahul uses the same password for another sys, the attacker is also able to access that sys

The attacker discovers that Rahul has access to customer info.

The attacker downloads a large amt of customer data.

What cybersecurity problem has occured?

Ans :- Possible answers-

- Phishing
- Credential theft
- Unauthorized access
- Data breach

Stage 2 :- Malware Attack

The attack sends another email to Rahul containing a malicious attachment.

Rahul opens the attachment.

Malware is installed on his computer

The malware begins communicating with the attacker's sys

The attacker now attempts to move from Rahul's computer to other systems within BrightMart's network.

Questions-

Which vulnerability allowed the attacker to move further into the organization?

Ans Students should identify possibilities such as:

- weak passwords
- Excessive user privileges
- Lack of MFA
- Poor network security
- Lack of employee awarness
- Outdated software

Page No.
Date

Stage 3 – Ransomware.

Two days later, employees arrive at work & discover that they cannot access imp files.
A message appears on their computers:

"Your files have been encrypted. Pay the ransom to recover them"

The company's customer database & several imp business files are encrypted.
Unfortunately, the company's most recent backups are almost a month old.

BrightMart's website stops working.
customers cannot place orders.
The customer-support team cannot access records.

Stage 4 – Business Impact

BrightMart now faces several problems.
Financial Impact
The company losses sales because its website is unavailable.
Data Impact:
Customers info may have been stolen
Operational Impact:
Employee cannot access imp sys.
Reputation Impact:
Customers lose confidence in the company.

Legal / compliance impact.

The company may face regulatory or legal consequence depending on what info was exposed & which laws apply

Group 1 – Identify the Threats

what threats are present in this case?

Ans – They may identify:

- Phishing
- Malware
- Ransomware
- Credential theft
- Unauthorized access
- Data theft

Group 2 – Identify the Vulnerabilities

what weakness in BrightMark's security allowed the attcle to succed?

Ans	Vulnerability	How it helped the attcker
	weak passwords	Easier password give access to multiple sys
	No MFA	Stolen password may be enough to log in
	lack of training	Employee falls for phishing.
	Delayed updates	Vulnerable software may be exploited
	Excessive privlege	Attackers can access more data
	Infrequent backups	Difficult to recover after ransomware

Group 3 – Apply the CIA traid.

Confidentiality

was confidential info exposed?

Ans Yes. Customer info was accessed / download by the attacker

Integrity

Was information changed or damaged?

Ans Yes. The attacker could modify or encrypt files potentially.

Availability.

Were sys available to legitimate users?

Ans No. The website & internal sys became unavailable because of ransomware.

confidentiality ⟶ Affected
Integrity ⟶ Affected
Availability ⟶ Affected

Page No.
Date

Group 4 — Security Solutions.

(1) who is responsible for cybersecurity

Ans Not only the IT department. Every employee who uses the organization's sys has a role in CBS

(2) was phishing the only problem?

Ans NO. Phishing was the intial attack. but weakness such as password reuse. lack of MFA. excessive privileges poor backups & insufficient training allowed the attack to become much more damaging.

(3) what was the biggest vulnerability?

Ans no single correct ans.

Lack of employee awarness was a major vulnerability because the attack started when Ranul clicked the phishing link.

Another student might argue:—

" Poor backup practices were the biggest problem b/c BrightMart could not quickly recover from ransomware

what should BrightMart do to prevent smt from happening again?

- Use strong password.
- Implement MFA
- Provide regular CBS awarness training.
- Keep software updated.
- Conduct phishing awarness exercises.
- Follow the principle of least privilege.
- Encrypt sensitive data
- Maintain regular backups.
- Monitor suspicious login activity.

Quick Assement.

① what was the Initial attack against Bright Mart?

Page No.
Date

Ans Phishing link

② Give 3 vulnerabilities that helped the attacker.
weak passwords
No MFA
Password reuse
Infrequent backups

③ which 3 security principles of CIA Triad were affected?
Lead to CIA
Non-repudiation
security

④ what was the impact on ransomware on BM?
Data theft

⑤ Suggest three security controls BM should implement
① MFA ② Encrypt sensitive data
③ Use strong password.

Done
31/8/26